

Project Specification: vetpkg

Pre-Flight Dependency Provenance & Slopsquatting Interceptor

1. Executive Summary & Problem Statement

Modern workflows incorporate LLM coding tools (Cursor, Copilot, Claude Code). While accelerating velocity, they introduce **AI Package Hallucination** and **Slopsquatting**.

- **Hallucination:** LLMs consistently invent plausible-sounding non-existent package names.
- **Deterministic Slopsquatting:** Attackers harvest hallucinated import names and register them on public registries (npm, PyPI, crates.io, Go Proxy).
- **Automated Ingestion:** Developers and autonomous agents run package installs without verifying provenance.

2. Goals & Core Principles

- **Zero-SaaS Architecture:** Direct queries to authoritative upstream registries without commercial feeds.
- **Sub-Second Latency:** Evaluates package metadata in <800ms to preserve CLI ergonomics.
- **Ecosystem Agnostic:** Unified support for npm, pip, Go modules, and cargo.

3. Heuristic Risk Scoring (0 - 100)

Heuristic Factor	Condition	Points	Description
Fresh Release	≤ 7 days old	+35	Highest hallucination / squat risk window
Infant Package	8 - 30 days old	+20	Elevated risk of premature ingestion
Single Version Trap	Total releases == 1	+15	Common for placeholder / slopsquat packages
Negligible Downloads	< 100 weekly downloads	+15	Lacks public adoption or verification
Detached / Fake Repo	No VCS link or 404 repo	+20	Claims open source but repository is missing
Lexical Conflation	Blends top 5,000 packages	+25	Synthesizes popular keywords (e.g. auth + jwt)
Author Ephemerality	Maintainer age < 30 days	+15	Newly created persona registered to push squat

4. Implementation Roadmap (8 Weeks)

- **Phase 1 (Weeks 1–3):** Core Go CLI scaffold, direct registry API clients (npm + PyPI), caching layer.
- **Phase 2 (Weeks 4–6):** Go proxy & crates.io adapters, lexical conflation engine.
- **Phase 3 (Weeks 7–8):** Shell integration shims (Zsh/Bash), SARIF / JSON output for CI pipelines.